



Fleet Wise — Full Test Plan

Everything to check before real users arrive

20 July 2026 (rev. 3) · <https://fleet-wise-delta.vercel.app> · [Print this and tick as you go](#)

Part 0 — Configuration status

Setup is complete and was verified against the live site on 20 July 2026. All three database migrations are applied, the environment variables are in place, and the daily reminder job runs successfully in production. The evidence is in Part 0.2 below. The one item still outstanding is OpenAI billing credit (0.3).

0.1 Database migrations — all applied

#	File	What it does	State
1	0002_ai_metering.sql	Counts AI questions in the database.	✓
2	0003_lock_plan_column.sql	Stops users granting themselves the unlimited plan.	✓
3	0004_reminders.sql	Reminder opt-out flag and send log.	✓
4	0005_token_budgets.sql	Daily token budgets (5,000 / 50,000 / 100,000).	✓

They were also applied in the right order, which matters: 0003 removes blanket write access to the organizations table and 0004 grants back the one column it needs. Both the plan lock and the reminder toggle were confirmed working together, so the ordering is correct.

0.2 Checks already run for you against the live site

Check	Result observed	State
Reminder job rejects callers without the secret	HTTP 401	✓
Reminder job runs with the secret	<code>{"ok":true,"checked":3,"sent":0,"skippedNothingDue":3}</code> — proves the service-role key and email provider are both configured	✓
AI endpoint refuses strangers	<code>{"error":"Not signed in"}</code> — HTTP 401	✓
Plan escalation attack (PATCH plan = business)	HTTP 403 permission denied; plan stayed <code>free</code>	✓
Quota tampering attack (writing ai_usage directly)	HTTP 403, row-level security violation	✓
Legitimate: rename garage / toggle reminders	HTTP 204 both	✓

Legitimate: simulated checkout to Premium	Plan became <code>pro</code> and the allowance rose with it	✓
Token budget: free plan ceiling	<code>{"limit":5000,"remaining":5000}</code>	✓
Token budget: debit 4,600 tokens	Remaining fell to 400, and the next request was refused (below the 600-token headroom)	✓
Token budget: upgrade to Business	Ceiling rose to 100,000 immediately; requests allowed again	✓
Budget refill time	Reported as the next UTC midnight	✓

This means Parts 6.1, 6.2 and 6.4 of this document are already proven — you can skip them unless you want to see the results yourself. Everything else still needs a human.

0.3 OpenAI billing — still outstanding

platform.openai.com → **Billing** → **Add payment details** → add about \$5 of credit and set a monthly spend cap. Until this is done, every AI request is refused and the app quietly serves "Offline answer (rules)" instead. **Part 4 of this plan cannot pass without it.**

Guard the service-role key. Anyone holding it can read, change or delete every user's data, ignoring all protections. Never paste it into a chat, a screenshot, the browser, or any file that gets committed. If it leaks, rotate it in the Supabase dashboard immediately.

Part 1 — Accounts and access SECURITY

#	Test	Expected result	Pass
1	Open the site signed out and type <code>/dashboard</code> in the address bar.	Bounced to the sign-in page. No fleet data ever appears.	☐
2	Repeat for <code>/vehicles</code> , <code>/copilot</code> , <code>/pricing</code> .	All bounce to sign-in.	☐
3	Create an account, leaving "Name your garage" empty.	Signup succeeds; garage is auto-named from your email.	☐
4	Sign up again with the <i>same</i> email.	Clear message: an account with this email already exists.	☐
5	Sign in with a deliberately wrong password.	"Wrong email or password" in a red box — never a raw error or <code>{}</code> .	☐
6	Use a 5-character password at signup.	Rejected with the 8-character rule explained.	☐
7	Sign out, then press the browser Back button.	You do not get back into the app; you land on sign-in.	☐

Part 2 — Vehicles and service records CORE

#	Test	Expected result	Pass
8	Add a vehicle: plate TRK-012 , Ford, F-150, 148200 km.	Appears in the list immediately.	☐
9	Reload the page (F5).	Vehicle is still there — proves it saved to the cloud, not the browser.	☐
10	Sign in on your phone with the same account.	The same vehicle appears. This is the real proof data lives in the database.	☐
11	Try to add a second vehicle with the same plate TRK-012 .	Rejected — duplicate plates are blocked per garage.	☐
12	Submit the add form with the plate left empty.	Clear validation message; nothing is saved.	☐
13	Enter letters in the mileage field.	Rejected with an explanation.	☐
14	Open the vehicle, log a service: Oil change, \$95, dated 7 months ago .	Record appears in the history table.	☐
15	Edit that record's cost, then reload.	The new cost persists.	☐
16	Delete the record.	Removed from the list and after reload.	☐
17	Delete a vehicle that has service records.	Vehicle and all its records disappear together — no orphans left behind.	☐

Part 3 — Dashboard intelligence CORE

Set this up first: one vehicle with an oil change **7 months ago** (interval is 6 months, so it is overdue), and one with an oil change **5 months ago** (due within 30 days).

#	Test	Expected result	Pass
18	Open the dashboard.	"Overdue services" shows 1; "Due in next 30 days" shows 1.	☐
19	Check the vehicle counter and this month's cost tile.	Both match what you entered.	☐
20	Add three brake repairs to one vehicle, all within the last 6 months.	An "abnormal pattern" warning names that vehicle and suggests finding the root cause.	☐
21	Give one vehicle far higher costs than the rest.	It is flagged as costing more than double the fleet average.	☐
22	Look at both charts.	Monthly cost bars and top-vehicles chart reflect your data; nothing overflows the screen.	☐

Part 4 — The AI copilot CORE

How to tell whether the real AI answered — read this first. Two signals appear on the copilot page:

- A small grey note under a reply saying **"Offline answer — the AI is unreachable right now"** means the built-in rules engine answered, not the language model.
- **The token counter under the composer did not move.** If it still reads "5,000 of 5,000" after you asked a question, no tokens were spent, which means no AI call succeeded. This is correct behaviour — users are never charged for a failed call — but it tells you the AI is not working yet.

A reply with no note *and* a counter that dropped (typically by 700–1,500) is proof the language model answered. Until OpenAI billing credit is added (Part 0.3), every test in this section will show the offline behaviour.

#	Test	Expected result	Pass
23	Ask: "Which vehicles need servicing this month?"	Names your actual overdue vehicles. Labelled AI answer .	☐
24	Ask: "Which vehicle costs me the most and why?"	Correct vehicle with real figures from your records.	☐
25	Honesty test. Ask about a plate you never entered: "Tell me about ZZZ-999".	Says it has no data for that vehicle. If it invents a history, that is a serious failure — tell me.	☐
26	Ask something unrelated: "What is the capital of France?"	Politely steers back to fleet matters.	☐
27	Ask a follow-up in your own words, e.g. "and the cheapest one?"	Sensible answer; no crash.	☐
28	Ask a question with an empty fleet (new account).	Says there are no vehicles yet and suggests adding one.	☐
29	Send a very long question (paste a paragraph).	Either answers or refuses cleanly — no blank screen.	☐

Part 5 — Plan limits and money REVENUE

#	Test	Expected result	Pass
30	On a Free account (5,000 tokens/day), ask questions while watching the counter under the composer.	It drops by roughly 700–1,500 per question. If it does not move at all, the AI is not answering — see the box in Part 4.	☐
31	Keep asking until fewer than 600 tokens remain.	Input locks; the banner says when the budget refills. No OpenAI call is made — this is what protects your bill.	☐
32	Reload the page and try again.	Still blocked — the budget lives in the database, not the browser.	☐
32b	Wait past midnight UTC (or check the next day).	The budget is full again automatically; no action needed by you or the user.	☐

33	Add 5 vehicles on a Free account, then try a 6th.	Blocked with an upgrade prompt.	☐
34	Go to Pricing and "Subscribe" to Premium.	Plan badge changes; the daily budget jumps to 50,000 tokens; vehicle limit rises to 50.	☐
35	Ask a question on the new plan.	Works again; the footer shows the bigger allowance.	☐
36	Downgrade back to Free.	Limits return to 5 vehicles / 5,000 tokens per day.	☐

Remember: "Subscribe" takes no money — it is a simulation until a payment provider is connected. Do not advertise paid plans publicly yet.

Part 6 — Security you should verify yourself SECURITY

These are the tests that protect your data and your wallet. Run them in a terminal (Git Bash). Replace `ANON` with your anon key and `TOKEN` with a signed-in user's token (browser DevTools → Application → Local Storage → the `sb-...-auth-token` entry → `access_token`).

6.1 Nobody can call the AI without signing in VERIFIED

```
curl -X POST https://fleet-wise-delta.vercel.app/api/copilot \
-H "Content-Type: application/json" -d '{"question":"hi"}'
```

Confirmed on 20 July: returns `{"error":"Not signed in"}`, HTTP 401. Strangers cannot spend your OpenAI credit.

6.2 Nobody can promote themselves to the unlimited plan VERIFIED

```
curl -X PATCH "https://YOUR-PROJECT.supabase.co/rest/v1/organizations?id=eq.YOUR_ORG_ID" \
-H "apikey: ANON" -H "Authorization: Bearer TOKEN" \
-H "Content-Type: application/json" -d '{"plan":"business"}'
```

Confirmed on 20 July: HTTP 403 "permission denied for table organizations"; the plan stayed `free`. A second attack — inserting a zeroed row into `ai_usage` to fake a quota reset — was also refused by row-level security. Re-run these yourself any time you change database permissions.

6.3 One garage cannot see another's vehicles

Create a second account, add a vehicle to each, then in account B run:

```
curl "https://YOUR-PROJECT.supabase.co/rest/v1/vehicles?select=registration" \
-H "apikey: ANON" -H "Authorization: Bearer TOKEN_B"
```

Expect: only account B's own vehicles. Account A's plates must never appear.

6.4 The cron endpoint rejects outsiders VERIFIED

```
curl -i https://fleet-wise-delta.vercel.app/api/cron/reminders
```

Confirmed on 20 July: HTTP 401 Unauthorized. Without the secret nobody can trigger mass emails to your users.

Part 7 — Maintenance reminder emails

Status: the job itself is confirmed working in production — it ran on 20 July, checked 3 garages and correctly emailed nobody, because no garage had anything due ("skippedNothingDue": 3). What remains untested is the actual delivery of an email, which needs a garage with an overdue service. Test 37 sets that up.

#	Test	Expected result	Pass
37	First create the condition: add a vehicle and log an oil change dated 8 months ago (interval is 6 months, so it is now overdue). Then trigger the job by hand: <code>curl -H "Authorization: Bearer zkKlnTWucAStyKiFfVuTwUQa4vVhzGIH0jBy4ZjieZg" https://fleet-wise-delta.vercel.app/api/cron/reminders</code>	JSON summary showing "sent": 1 . If it shows "failed" with a Brevo error, the sender address is not verified in Brevo.	☐
38	Check your inbox (and spam folder).	Branded email from "Fleet Wise" listing the right vehicles with correct overdue/due badges.	☐
39	Click "Open my dashboard" in the email.	Lands on your live dashboard, not localhost.	☐
40	Run the same command again immediately.	"skippedAlreadySent": 1 and no second email . This is the anti-spam protection.	☐
41	Untick "Email me maintenance reminders" on the dashboard, then run it again (use a fresh day or clear that garage's <code>reminder_log</code> row).	That garage is skipped entirely.	☐
42	Run it with a garage that has nothing due.	"skippedNothingDue" increments; no pointless email.	☐
43	Wait for the scheduled run (07:00 UTC) or check Vercel → your project → Cron Jobs.	The job appears and shows a successful execution.	☐

Part 8 — Phone, tablet and browser

#	Test	Expected result	Pass
44	On a phone, open every page: dashboard, vehicles, a vehicle's detail, copilot, pricing.	Nothing overflows sideways; text is readable without zooming.	☐
45	Tap the hamburger menu.	Full-height drawer slides in; background dims; tapping outside closes it.	☐

46	Tap into a form field on an iPhone.	The page does not zoom in awkwardly.	☐
47	Use the copilot on the phone.	Chat fills the screen; the input stays reachable above the keyboard.	☐
48	Rotate the phone to landscape; try a tablet if you have one.	Layout adapts; nothing is cut off.	☐
49	Switch your device to dark mode.	The app follows; all text stays readable.	☐
50	Try a second browser (Chrome and Firefox, or Safari).	Same behaviour throughout.	☐

Part 9 — When something fails

Symptom	Most likely cause	Fix
Replies are marked "Offline answer", or the token counter never moves	Almost always: no OpenAI billing credit. The app falls back to the rules engine and charges nothing.	Add credit at platform.openai.com → Billing. Confirm in Vercel → Logs, where the OpenAI error is printed in full.
Counter shows "0 of 0 tokens"	Migration 0005 not applied, or the user has no garage yet	Run <code>0005_token_budgets.sql</code> ; sign out and back in.
Signup fails with a 500	Supabase's built-in email limit	Connect Brevo SMTP, or keep "Confirm email" off while testing.
Reminder job returns 503	Missing service-role key or email key	Add the env vars, then redeploy.
Emails land in spam	Sending from a generic address without a domain	Expected on the free setup; buy a domain and verify it in Brevo to fix properly.
Sign-in suddenly fails for everyone	Supabase free project paused after a week idle	Open the Supabase dashboard to wake it; upgrade before launch.

Part 10 — Before you let real users in

1. Turn **"Confirm email" back on** in Supabase (Authentication → Sign In / Providers) once Brevo SMTP is connected — otherwise anyone can register with someone else's address.
2. Delete the two security-test accounts left from the 20 July verification — `sectest1784549039@example.com` and `sectest1784549097@example.com` — in Supabase → Authentication → Users. Their garages were already removed. Then run `delete from organizations where id not in (select org_id from memberships);` to clear any other orphaned test garages.
3. Rotate the OpenAI key (it was shared in plain text during development) and set a monthly spend cap.
4. Upgrade Supabase and Vercel off the free tiers, so the project cannot pause and you are licensed for commercial use.
5. Connect a real payment provider before advertising paid plans, then delete `set_plan_simulated()` from the database.
6. Add a privacy policy and terms — you are storing other people's email addresses and vehicle data.

Fleet Wise test plan — 20 July 2026. Report anything that fails, especially test 25 (invented data) and test 6.2 (plan escalation).